

Third-Party Assessment Pack

Vendor under assessment: **CloudLedger Technologies Ltd**, running the "OriginateCloud" loan-origination platform. This pack contains everything an assessor needs: the client's risk rules, the vendor's profile, the vendor's completed security questionnaire, and all supporting assurance evidence. Assess it using the Weekly Project 03 build guide and workbook.

CLIENT (ASSESSOR)

Meridian Trust Bank plc, retail & commercial bank, UK & Ireland

VENDOR (ASSESSED)

CloudLedger Technologies Ltd, SaaS, London

SERVICE

OriginateCloud, cloud loan origination & document management

ASSESSMENT REFERENCE

MTB-TPRM-2026-0417

PACK COMPILED

July 2026

STATUS

Fictional scenario, training use only

How to use this pack. Everything here is invented for training. The evidence is written to look exactly like the real thing, and it contains real problems planted at every severity level. Read it the way an assessor does, sceptically, checking every date, scope line and exception.

A Client profile & risk rules: Meridian Trust Bank

Client overview

INTERNAL REFERENCE

Organisation	Meridian Trust Bank plc
Sector / regulation	Retail & commercial banking. Regulated for prudential and conduct purposes; in scope for operational-resilience rules in the UK and, via its Dublin branch, for the EU Digital Operational Resilience Act (DORA).
Size	~2,400 staff; ~1.1m retail customers across the UK and Ireland.
Why this assessment exists	The retail lending team wants to adopt CloudLedger's OriginateCloud platform to process personal-loan and mortgage applications. Because the platform will hold customer personal and financial data inside a core business process, Meridian's policy requires a third-party risk assessment and a documented risk decision <i>before</i> go-live.

Extract: Meridian Third-Party Risk Management Policy (v4.2)

THE RULES YOU ASSESS AGAINST

1. Vendor tiering

Every vendor is tiered by **inherent risk**, scored on four factors (data sensitivity, operational criticality, regulatory exposure, and system/network access). The tier sets the minimum due diligence required:

Tier	Typical vendor	Minimum evidence required
Critical	Holds customer PII/financial data inside a critical or important business function	SOC 2 Type II <i>or</i> ISO 27001, external penetration test (annual), evidenced DR test (annual), DPA, subprocessor list, right-to-audit
High	Holds sensitive data or supports an important process	SOC 2 Type II <i>or</i> ISO 27001, DPA, security questionnaire
Medium	Limited data, non-critical process	Security questionnaire, DPA if personal data involved
Low	No sensitive data, no material dependency	Signed contract with security clauses

2. Risk appetite (extract)

Meridian's board-approved appetite for third-party risk:

- Meridian will **not accept** any open **Critical** finding on a vendor supporting a critical or important function. Such findings must be remediated before go-live or the vendor rejected.
- Open **High** findings may be accepted only with a documented remediation plan and a deadline of no more than **30 days**, signed off by the accountable risk owner.
- The bank has **low appetite** for concentration risk and for personal data being processed outside the UK/EEA without an approved transfer mechanism.

3. Risk rating & decision authority

Findings are rated **likelihood** × **impact** on a 5×5 scale (Low 1–4, Medium 5–9, High 10–14, Critical 15–25). Residual risk acceptance authority: Medium: team lead; High: Head of Risk; Critical: cannot be accepted (must remediate or reject). The assessor **recommends**; the accountable risk owner **decides**.

B Vendor profile: CloudLedger Technologies

Vendor overview & service description

VENDOR-SUPPLIED

CloudLedger Technologies Ltd

Company profile · supplied to Meridian Trust Bank · Ref MTB-TPRM-2026-0417

Founded / stage	2021. Series A funded (~£9m raised, 2024). ~45 employees.
Product	OriginateCloud , a SaaS platform that lets lenders capture loan applications, collect and store supporting documents (payslips, bank statements, ID), run affordability checks and manage the origination workflow.
Hosting	Amazon Web Services, single region: <code>eu-west-1</code> (Ireland). No secondary region currently configured.
Data held for Meridian	Customer full name, address, date of birth, contact details, income and employment data, bank statements, and scanned identity documents (passport / driving licence). Estimated 40,000+ customer records within 12 months of go-live.
Client base	7 lenders. Meridian would be CloudLedger's largest client by volume.
Certifications claimed	SOC 2 Type II; ISO/IEC 27001.

Data flow (as supplied)

Customer submits an application through Meridian's website → data sent over TLS to OriginateCloud (AWS eu-west-1) → documents stored in encrypted object storage → identity documents sent to a third-party ID-verification API → application processed by CloudLedger staff and Meridian's lending team → decision returned to Meridian. Customer-support queries are handled by CloudLedger's **offshore delivery centre located outside the UK and EEA**, whose agents can access the production application to assist users.

Subprocessors (fourth parties), as declared

Subprocessor	Purpose	Location	Data accessed
Amazon Web Services	Hosting & storage	Ireland (eu-west-1)	All application data (encrypted)
VerifyID Ltd	Identity verification API	UK	Identity documents, name, DOB
MailRelay Inc.	Transactional email	United States	Name, email address
CloudLedger Support (offshore)	Customer support / L1	Outside UK/EEA	Full production access to customer records

Note for the assessor: the declared subprocessor list is complete and honest, but read it against the questionnaire answers on data transfers and flow-down of security obligations. What is *declared* and what is *controlled* are not the same thing.

C Vendor security questionnaire: CloudLedger's answers

CloudLedger completed Meridian's standard security questionnaire. The answers are below, grouped by the ten control domains. Treat each answer as a *claim*. For each, decide your verdict (Met / Partially / Not met / N/A) by checking it against the evidence in Section D. Some answers are fully backed; some are confident but unproven; some quietly contradict the evidence.

Section 1 · Governance, risk & security policy

1.1 Do you maintain a documented information security policy approved by senior management?

Yes. We maintain a full information security policy. See attached (Section D).

1.2 How often is the policy reviewed?

Annually. Our policy states it is reviewed at least annually.

1.3 Who owns information security in your organisation?

Security is overseen by our engineering leadership. We are recruiting a dedicated security lead.

Section 2 · Access control & identity

2.1 Is multi-factor authentication (MFA) enforced for all access?

Yes. MFA is enforced for all users of the OriginateCloud application.

2.2 Is MFA enforced for administrative and remote (VPN) access to your production environment?

Administrative access is restricted to senior engineers. VPN access uses username and password. MFA on the internal admin console is on our roadmap.

2.3 Do you perform periodic access recertification (reviewing who has access)?

Yes, access is reviewed.

2.4 Are shared or generic accounts used?

A small number of shared service/admin accounts are used by the engineering team for operational tasks.

Section 3 · Data protection & encryption

3.1 Is customer data encrypted at rest?

Yes. All data at rest is encrypted with AES-256 (AWS-managed encryption).

3.2 Is customer data encrypted in transit?

Yes. Customer-facing traffic uses TLS 1.2 or higher.

3.3 Is any customer personal data processed or accessible outside the UK/EEA?

Yes. Our offshore support centre can access production data to assist customers.

3.4 What transfer mechanism governs that access (e.g. Standard Contractual Clauses / adequacy)?

Our data processing agreement references appropriate safeguards.

3.5 What is your data retention schedule?

Data is retained for as long as necessary to provide the service.

Section 4 · Vulnerability & patch management

4.1 Do you perform regular vulnerability scanning?

Yes, automated vulnerability scanning runs monthly against production.

4.2 Do you commission independent penetration testing?

Yes, we commission an annual external penetration test. See summary in Section D.

4.3 Are all findings from the most recent test remediated?

The majority of findings have been remediated. A small number remain in progress.

Section 5 · Secure development & change management

5.1 Do you follow a secure software development lifecycle with peer code review?

Yes. All code changes go through pull-request review before merge.

5.2 Are development, test and production environments separated?

Yes, environments are logically separated in AWS.

Section 6 · Logging, monitoring & incident response

6.1 Do you maintain a documented incident response plan?

Yes. See attached (Section D).

6.2 What is your committed timeframe to notify a client of a personal-data breach affecting them?

We will notify affected clients promptly following confirmation of an incident.

6.3 When did you last test the incident response plan (e.g. a tabletop exercise)?

The plan is reviewed by the engineering team.

Section 7 · Business continuity, DR & resilience

7.1 Do you have documented recovery objectives (RTO / RPO)?

Yes. RTO 8 hours, RPO 4 hours.

7.2 Is the service deployed across more than one region/availability zone for failover?

The service runs in AWS eu-west-1 across multiple availability zones. A second region is planned.

7.3 When did you last perform a disaster-recovery / failover test?

Backups are taken continuously and DR procedures are documented.

Section 8 · Fourth-party / subcontractor management

8.1 Do you maintain a list of subprocessors and notify clients of changes?

Yes. Our subprocessor list is provided in Section B.

8.2 Do you flow down your security and data-protection obligations to subprocessors, and assess them?

We use reputable providers such as AWS. Our offshore support is delivered by a long-standing partner.

Section 9 · Compliance, certifications & assurance

9.1 Do you hold a current SOC 2 report? Which type and scope?

Yes, SOC 2 Type II. Summary attached (Section D).

9.2 Do you hold a current ISO/IEC 27001 certificate? What is its scope?

Yes, ISO/IEC 27001 certified. Certificate attached (Section D).

9.3 Do you grant clients a right to audit?

We provide our SOC 2 report in place of individual client audits.

Section 10 · Physical & personnel security

10.1 Do you perform background/pre-employment screening on staff with access to customer data?

Yes, UK employees undergo background screening.

10.2 Does screening extend to offshore support staff and contractors with production access?

Offshore support is provided through our delivery partner under their own HR processes.

D Supporting evidence

Evidence D1 · SOC 2 Type II report: summary page

INDEPENDENT AUDITOR

Harrow & Vale LLP, Assurance Services

SOC 2 Type II · CloudLedger Technologies Ltd · OriginateCloud platform

Report type	SOC 2 Type II (controls tested over a period)
Trust services criteria in scope	Security only. Availability, Confidentiality, Processing Integrity and Privacy were not in scope.
Period covered	1 April 2024 – 31 March 2025
Report issued	28 May 2025
Systems in scope	OriginateCloud production environment, AWS eu-west-1. The offshore support operation was excluded from the examination boundary.
Opinion	Unqualified, subject to the exceptions noted below.

Exceptions noted by the auditor

- For 3 of 12 quarters sampled, the quarterly user access review was not completed within the policy timeframe.
- For 1 of 5 terminated users sampled, access was removed 14 days after termination, against a stated 24-hour deprovisioning policy.
- MFA was enforced on the customer application but was **not** enforced on the internal administrative console during the period.

Complementary user entity controls (CUECs)

The report states that Meridian, as the user entity, is responsible for: configuring its own users' access appropriately, managing its own API keys, and reviewing CloudLedger's subprocessor notifications.

Meridian has not yet actioned these CUECs.

Evidence D2 · ISO/IEC 27001 certificate

CERTIFICATION BODY

Northgate Certification Ltd (UKAS-accredited)

Certificate of Registration · ISO/IEC 27001:2022

Certified organisation	CloudLedger Technologies Ltd
Certificate number	NG-27001-4471
Original certification	1 September 2023
Current expiry	31 August 2026 (surveillance audit pending)
Scope of certification	"The information security management system supporting the design, development and operation of the OriginateCloud platform at the London office. The offshore customer-support operation is excluded from the scope of this certification. "

Redcliff Security, Offensive Testing

External network & web application penetration test · OriginateCloud

Test type	External, unauthenticated. Web application & external network perimeter.
Test date	May 2025
Internal / authenticated test	Not performed.
Findings	1 Critical (remediated), 3 High, 5 Medium, 7 Low.

High findings: remediation status (as of latest client update)

Finding	Status
H1 · Deprecated TLS 1.0/1.1 still enabled on a legacy support endpoint	Open (past 90-day SLA)
H2 · Administrative console reachable from the internet without MFA	Open (past 90-day SLA)
H3 · Verbose error messages disclosing stack traces	Remediated

CloudLedger Technologies · Information Security Policy

Document control extract

Document version	1.3
Last reviewed / approved	January 2024
Review cycle (per this policy)	"This policy shall be reviewed at least annually and upon significant change."
Document owner	(field blank)
Approved by	(no senior-management sign-off recorded)

Policy content covers access control, acceptable use, encryption standards and incident handling at a high level. The content is reasonable; the document-control fields are not.

CloudLedger Technologies · Incident Response Plan

Extract

- Defines incident severity levels (P1-P4) and an on-call escalation path to engineering leadership.
- Describes containment, eradication and recovery steps for common incident types.
- **Client / data-controller breach notification:** the plan states clients will be informed "promptly" but defines **no committed timeframe** (e.g. no 24 / 48 / 72-hour SLA).
- **Testing:** the plan states it "should be exercised periodically." **No record of a tabletop or live exercise in the last 12 months is provided.**

CloudLedger Technologies · BCP / DR Summary

Extract

Recovery objectives	RTO 8 hours · RPO 4 hours
Backups	Automated backups to encrypted object storage, retained 35 days. Backups stored in the same region (eu-west-1).
Regional resilience	Single region (eu-west-1) across multiple availability zones. No secondary region / cross-region failover configured.
Last DR / failover test	February 2024 (partial). No full failover test evidenced since.

Draft Master Services Agreement & DPA: key terms

CloudLedger ↔ Meridian Trust Bank

DPA in place	Yes Signed data processing agreement covering CloudLedger as processor.
International transfer safeguards	DPA references "appropriate safeguards" for transfers outside the UK/EEA. Standard Contractual Clauses are named but not attached, and no transfer risk assessment is provided for the offshore support access.
Right to audit	Not present. The draft contract contains no clause granting Meridian a right to audit CloudLedger; SOC 2 is offered instead.
Breach notification deadline	Not specified. Contract requires notification "without undue delay" but sets no fixed hours.
Retention & deletion on exit	Deletion on termination is committed, but the retention schedule is stated only as "as long as necessary."
Encryption / key management	Encryption at rest is AWS-managed (AES-256). Ownership and management of encryption keys is not documented in the agreement.

Several items here are **Meridian's** to fix at contracting (right to audit, breach-notification deadline, attaching SCCs) rather than CloudLedger's security failings. A strong assessment separates "vendor must remediate" from "we must remediate before signing."